

AI Audit Report — HW06 API Testing (§9, phụ lục bắt buộc)

- **Sinh viên:** Lê Nhựt Duy — **MSSV:** 23127178
- **AI Policy của bài:** Open — **bắt buộc** có lời khai + audit đầy đủ. §17: thiếu tài liệu bắt buộc = 0 điểm.

I use AI tools for the following tasks.

Công cụ đã dùng (§8)

Công cụ	Việc
Claude Code (Opus 5)	chọn API, sinh test case, audit, viết collection Postman, tooling, báo cáo
Postman + Newman	thực thi test case, xuất HTML report
(bổ sung nếu dùng thêm)	

Cách đọc file này

Mỗi lượt hỏi AI = một mục `Interaction #N`, ghi đủ 5 trường §9 (tool · ngày giờ · prompt nguyên văn · output · human review) cộng 3 trường riêng của HW06 (bước trong quy trình · AI sai/bỏ sót · vì sao bỏ sót). Ba trường sau chép thẳng được sang §11 của `report/main-report.md`.

Trường **Human review** ghi **ai kiểm gì**, không viết gộp thành "đã kiểm hết": - **(SV đã kiểm)** — sinh viên đã tự chạy lại / đối chiếu spec / đối chiếu source, kèm ngày và phạm vi. - **(phần đọc của SV: chưa)** — AI đã soát được phần nào thì ghi rõ phần đó (kèm phép kiểm bằng máy), và ghi rõ **file sinh viên còn phải đọc**. Không viết "đã kiểm" thay sinh viên: §11 phạt đúng loại bằng chứng đó, và ba lượt AI tự soát (Interaction #12, #13) đều còn tìm ra lỗi — nên lớp đọc của người vẫn là lớp kiểm soát thật, không phải thủ tục.

Interaction #1

- **API / Bước:** chọn API cho 3 pool (trước §6.1)
- **Bước trong quy trình:** chọn phạm vi — §5
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-18 23:17
- **Prompt:** (ảnh chụp 4 bộ API các bạn đã chọn) + "những cái trên là cái api mà bạn tui nó chọn. bạn hãy dựa vào yêu cầu đề bài chọn cho tui các api khác đi" + file đề 2026.HW06.API Testing_En.pdf
- **AI output (tóm tắt):** đọc đề + `api_specification.md` + `backend/server.js`, đối chiếu 4 bộ API đã bị lấy, đề xuất bộ 3 chưa ai chọn: `GET /api/products` (A/FR-05) · `POST /api/cart` (B/FR-07) · `PUT /api/products/:id` (C/FR-15), kèm giả thuyết bug rút từ source (SQL nối chuỗi ở :143, không validate ở :290, thiếu `authenticateToken` ở :179) và 2 phương án dự phòng.

- **AI sai / bỏ sót:** (chưa đánh giá — bộ API mới chỉ là đề xuất, chưa chạy request nào để xác nhận các giả thuyết bug)
- **Vì sao bỏ sót:** —
- **Human review:** (phần đọc của SV: chưa) — **AI đã soát:** `check-cases.mjs` xác nhận mọi case của 3 API trở được vào spec §/FR/SEC (bất biến 2). **SV đã làm:** chốt bộ 3 API sau khi đối chiếu ảnh chat nhóm. **Còn lại:** SV đọc `docs/api-selection.md` để tự xác nhận lập luận chọn API — `npm run review 1`.
- **Commit:** `107033b`

Interaction #2

- **API / Bước:** dựng khung repo + tooling (trước §6.1)
- **Bước trong quy trình:** setup
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-18 23:30
- **Prompt:** rùi bây giờ bạn hãy tham khảo HW01, HW02 làm giùm tui do hai bài đó có điểm. hãy setup trước trong repo `/Users/macOS/Documents/HK3_Nam3/kiem_thu/HW06-API-Testing`
- **AI output (tóm tắt):** đọc quy ước HW01/HW02/HW05, dựng khung HW06: cấu trúc thư mục theo §14, `docs/api-selection.md` (bằng chứng §5), tooling (`preflight · seed-api-data · run-newman · summarize-newman · ci-gate · tc2xlsx · build-pdfs · verify-all · package · commit-plan`), environment + pre-request script Postman, workflow GitHub Actions, 4 Agent Skill, và các file template rỗng, mỗi file đánh dấu rõ trạng thái *chưa hoàn thành* để một bản dờ dang không thể trông như đã xong (`verify-all.sh` và `package.sh` fail khi dấu đó còn).
- **AI sai / bỏ sót:** ghi 2 file vào thư mục HW05 do lỗi thư mục làm việc, đã phát hiện và chuyển về HW06 + hoàn nguyên HW05.
- **Vì sao bỏ sót:** đặc điểm công cụ (shell giữ cwd giữa các lệnh) — không phải giới hạn của model.
- **Human review:** (phần đọc của SV: chưa) — **AI đã soát:** `verify-all.sh` 37 mục xanh. **SV đã làm:** tự chạy chính bộ tooling này (`verify-bugs.sh x3, npm run test:all`) trên máy mình ngày 23/08 — tức phần tooling đã được kiểm bằng cách dùng thật, không phải bằng cách đọc. **Còn lại:** SV đọc README §5-§6 — `npm run review 2`.
- **Commit:** `72ae9b1`

Interaction #3

- **API / Bước:** cả 3 API — kiểm chứng giả thuyết bug trước khi thiết kế test case
- **Bước trong quy trình:** api-test-design bước 1 (rút ràng buộc) — phần đối chiếu hành vi thật
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-18 23:55
- **Prompt:** rùi bạn hãy làm toàn bộ những j bạn có thể làm đi rùi nói tui (lượt này là bước đầu tiên AI tự chia: viết script probe gửi ~60 request thật để kiểm 12 giả thuyết bug rút từ đọc source, TRƯỚC khi viết test case — để expected không dựa trên suy đoán)
- **AI output (tóm tắt):** script `probe.mjs + probe2.mjs` gửi request thật cho cả 3 API. Kết quả: xác nhận SQLi (`% OR '1'='1` → toàn bộ bảng), lỗi DB trả HTML kèm `SQLITE_ERROR`, `GET /api/products/:id` không tồn tại → `200 {}`, `price` là **string** khi id chẵn, `POST /api/cart` nhận mọi input sai, giả **không** xóa sau checkout, `PUT/POST/DELETE /api/products` **không cần token**, partial update ghi NULL đề. Phát hiện **ngoài dự kiến:** SUT **chết giữa lúc probe** — chuỗi `PUT-`

không-token → price NULL → GET id chặn → `row.price.toString()` trên null → TypeError không bắt → tiến trình node kết thúc (**BUG-14**).

- **AI sai / bỏ sót:** —
- **Vì sao bỏ sót:** —
- **Human review: (SV đã kiểm)** — 23/08/2026 00:09, sinh viên tự chạy `bash bug-report/verify-bugs.sh 14, 13, 08` trên máy mình và tận mắt thấy: BUG-14 làm **tiến trình backend chết** (HTTP 000 + stack trace `TypeError: Cannot read properties of null (reading 'toString')` tại `server.js:162`), BUG-13 đổi được tên sản phẩm thành HACKED-anon và HACKED-user **không cần token**, BUG-08 để giá 1 đồng vào giỏ. Cả 3 đều tái hiện được. **Chưa tự chạy 16 bug còn lại** (chúng nằm trong `verify-bugs-output.txt`).
- **Commit:** 8a244d9

Interaction #4

- **API / Bước:** API-01 · API-02 · API-03 — sinh test case
- **Bước trong quy trình:** api-test-design bước 1→5 (mỗi API một lượt, mỗi bước một mục trong file spec)
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:05
- **Prompt:** (cùng lượt #3 — AI tự chia thành các bước theo skill `api-test-design`)
- **AI output (tóm tắt):** 3 file `generator/specs/*.mjs` định nghĩa **136 test case** (109 AI + 22 SV + 24 setup/teardown) theo 4 nhóm §6.1, kèm cột Căn cứ cho từng case; và `tools/gen-artifacts.mjs` sinh ra bảng Markdown 12 cột + collection Postman từ cùng nguồn.
- **AI sai / bỏ sót:** 1. **Bịa expected** ở 3 case chỗ spec im lặng: TC-PRODLIST-011 (`search=""` → "0 dòng"), TC-CART-008 ("vượt tồn kho" — bảng không có cột tồn kho), TC-PRODUPD-005 (`name` 300 ký tự → 400). 2. **Sinh mã JS lỗi cú pháp:** tên `pm.test` chứa giá trị chuỗi không escape dấu `"` → 2 case đổ với `missing`) after argument list (không phải bug SUT). 3. Ban đầu định đặt chuỗi làm sập SUT (BUG-14) **vào trong collection** — sẽ làm mọi case sau đổ vì môi trường.
- **Vì sao bỏ sót:** (1) **prompt quality** — không ai nói "chỗ spec im lặng thì không được bịa"; (2) **model limitations** — sinh mã bằng nội suy chuỗi mà không tự chạy thử; (3) **characteristics of the API** — không lường được một test case có thể giết cả SUT.
- **Human review: (phần đọc của SV: chưa)** — **AI đã soát:** `check-cases.mjs` (136 case · 7 bất biến nội dung · 0 vấn đề) và `check-expect-vs-checks.mjs` (135 case có assert status · 0 case lệch). **SV đã làm:** chạy toàn bộ 3 collection và tự thấy 29/30/30. **Còn lại:** SV đọc `test-cases/*/generated.md` — `npm run review 4`.
- **Commit:** 29ef95c

Interaction #5

- **API / Bước:** cả 3 API — audit (§6.2) + thêm case AI bỏ sót (§6.3)
- **Bước trong quy trình:** api-test-audit
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:10
- **Prompt:** (cùng lượt — bước audit chạy riêng sau bước sinh, không gộp)
- **AI output (tóm tắt):** dán nhãn 109 case AI (**106 VALID · 3 INCOMPLETE đã sửa**), viết 3 mục `auditNotes`, và thêm **22 case sinh viên** với bảng "vì sao AI bỏ sót" phân loại đúng 3 nhóm §6.3.

- **AI sai / bỏ sót:** đây là **AI tự audit output của chính nó** — một hạn chế phải nói rõ: nó bắt được loại lỗi *thiếu căn cứ trong spec* (vì kiểm được bằng cách đối chiếu văn bản), nhưng không có gì bảo đảm nó bắt được lỗi thuộc loại *chính nó không nghĩ tới*. Chính vì vậy 22 case §6.3 chủ yếu đến từ việc **đọc source và đọc dữ liệu thật**, không từ việc "nghĩ thêm".
- **Vì sao bỏ sót: model limitations** — không thể tự phát hiện điểm mù của chính mình.
- **Human review:** (phần đọc của SV: chưa) — **AI đã soát:** lượt thứ ba soát **nội dung** 114 nhãn `VALID` và tìm ra lỗi #22 (TC-CART-101/102 gán nhãn Security mà không trả được SEC-0x nào). **Đây là mục AI KHÔNG THAY ĐƯỢC:** §6.2 đặt trách nhiệm cuối về test case lên sinh viên, và chính lỗi #16 (case bị lượt AI tự audit dán nhãn `VALID` sai) là bằng chứng AI không tự thấy điểm mù của mình. **Còn lại:** SV đọc `test-cases/*/audit.md + extended.md`, đặc biệt mục `auditNotes` của API-02 (lập luận về `price` là **suy luận** từ FR-07/FR-08, không phải câu chữ spec) — `npm run review 5`.
- **Commit:** `b0bb70c`

Interaction #6

- **API / Bước:** cả 3 API — thực thi (§6.4)
- **Bước trong quy trình:** postman-newman
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:24
- **Prompt:** (cùng lượt)
- **AI output (tóm tắt):** chạy 3 collection bằng Newman trên SUT thật: **171 request · 329 assertion · 240 xanh · 89 đỏ**; sinh `summary.md` tự động từ raw JSON; điền baseline cổng CI (29/30/30).
- **AI sai / bỏ sót:** lượt chạy **đầu tiên** có 4 assertion đỏ **không phải** do SUT: 2 do lỗi cú pháp JS (mục #4), 2 do seed user2 chạy trước khi SUT seed xong bảng `users` (đỏ vì môi trường). Nếu không truy nguyên, cả 4 sẽ bị báo thành bug của SUT.
- **Vì sao bỏ sót: characteristics of the API** — `database.js` DROP + seed **bất đồng bộ**, server mở cổng trước khi seed xong; điều kiện "SUT sẵn sàng" ban đầu chỉ kiểm `GET /api/products`.
- **Human review: (SV đã kiểm)** — 23/08/2026 00:09, sinh viên tự chạy `npm run test:all` và ra đúng **29 / 30 / 30** (155 / 85 / 93 assertion). Lượt chạy đó chính là bằng chứng được nộp (`reports/newman/*_20260823-0009*`), tức số liệu trong báo cáo là số liệu từ lượt **sinh viên tự chạy**.
- **Commit:** `146aa7c`

Interaction #7

- **API / Bước:** bug report (§6.5)
- **Bước trong quy trình:** sau execution
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:30
- **Prompt:** (cùng lượt)
- **AI output (tóm tắt):** `bug-report/verify-bugs.sh` tái hiện **19/19 bug** bằng curl (kèm chuỗi làm sập SUT và tự khởi động lại), log lưu ở `verify-bugs-output.txt`; `bug-report.md` với 19 bug + **4 giả thuyết bị loại** sau khi kiểm chứng.
- **AI sai / bỏ sót:** ban đầu script giữ pipe của tiến trình con nên lệnh gọi bị treo tới timeout — lỗi plumbing, đã sửa bằng `< /dev/null`.
- **Vì sao bỏ sót: model limitations** (chi tiết về fd của shell).

- **Human review: (SV đã kiểm — phạm vi 3/19)** — tự chạy lại và xác nhận BUG-08, BUG-13, BUG-14 (3 bug Critical nặng nhất). 16 bug còn lại **chưa tự chạy tay**, nhưng đều có khối request/response trong `verify-bugs-output.txt` và chạy lại được bằng `bash bug-report/verify-bugs.sh <số>`. 19 GitHub Issue đã mở (#323–#341).
- **Commit:** `df986df`

Interaction #8

- **API / Bước:** báo cáo, traceability, Excel, README
- **Bước trong quy trình:** tổng hợp
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:40
- **Prompt:** (cùng lượt)
- **AI output (tóm tắt):** `report/main-report.md` (12 mục, bảng 11 lỗi của AI), traceability matrix (phủ FR-05...FR-15 + SEC-01...SEC-07, ghi rõ 2 ô ngoài phạm vi), `excel/23127178_HW06_TestCases.xlsx`, cập nhật README + danh sách Postman feature.
- **AI sai / bỏ sót:** xuất Excel lần đầu ra **250 dòng** thay vì 136 — gộp cả `generated.md` lẫn `audit.md` nên mỗi case AI bị đếm hai lần. Phát hiện vì con số không khớp với `summary.md`.
- **Vì sao bỏ sót: prompt quality** — `audit.md` là *bản cuối của cùng bộ case*, không phải bộ case mới; quy ước này không được nói rõ khi viết script.
- **Human review: (phần đọc của SV: chưa)** — **AI đã soát:** `check-claims.mjs` (18 con số công bố · link nội bộ · hash commit — 0 lệch) và lượt soát thứ hai tìm ra 3 lỗi tài liệu (#19 hash bịa, #20 bảng đánh số trùng, #21 trở file cũ). **Còn lại:** SV đọc `report/main-report.md` §11 (bảng 23 lỗi) và §12 (9 giới hạn) — `npm run review 8`.
- **Commit:** `80965eb`

Interaction #9

- **API / Bước:** cả 3 API — kiểm tính tái lập của lượt chạy
- **Bước trong quy trình:** postman-newman (sau execution)
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:48
- **Prompt:** (cùng lượt — bước tự kiểm sau khi có kết quả)
- **AI output (tóm tắt):** chạy lại toàn bộ 3 collection để đối chiếu với lượt đã ghi vào báo cáo. API-02 ra **34** đồ thay vì 30. Tái hiện thủ công **3/3 lần**: `POST /api/register` trả `200 {"id":3}` rồi user biến mất khỏi `GET /api/admin/users`. Nguyên nhân: server phục vụ request bằng dữ liệu cũ trong `database.sqlite` trong lúc `DROP TABLE users` của `database.js` chưa chạy; dòng log "*Database initialized and seeded*" in ra **trước** khi SQL chạy xong. Sửa: mốc sẵn sàng = **ghi rồi kiểm chứng bản ghi còn sống** (tối đa 12 lần thử), và seed thất bại thì **chặn** lượt chạy. Sau khi sửa: **3 lượt liên tiếp đều 29/30/30**.
- **AI sai / bỏ sót:** bản sửa ở lượt #6 ("*mốc sẵn sàng = login admin được*") **chưa đủ** — nó chỉ chứng minh có một bảng `users` nào đó có dữ liệu, không chứng minh đó là bảng mới sau khi DROP.
- **Vì sao bỏ sót: characteristics of the API** — không lường được rằng file SQLite cũ vẫn phục vụ được request trong cửa sổ giữa `listen()` và `DROP TABLE`.
- **Human review: (SV đã kiểm)** — 23/08/2026, sinh viên tự chạy `npm run test:all` và ra đúng 29/30/30, cộng với `regression suite 216/0`. Đây là lượt thứ **8** cho cùng kết quả (3 local trước đó,

2 trên CI, 2 local hôm nay, 1 regression) — nghĩa là con số 29/30/30 tái lập được ở tay người khác, không chỉ trong phiên làm bài.

- **Commit:** 1321895

Interaction #10

- **API / Bước:** tự chấm bài theo tiêu chí §15 rồi sửa những chỗ bị trừ
- **Bước trong quy trình:** review toàn bài
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-22 21:50
- **Prompt:** hãy đọc lại toàn bộ bài làm trong hw06 và dựa vào tiêu chí (file đề) chấm điểm cho tui bài làm hiện tại
- **AI output (tóm tắt):** chấm 92/100 và liệt kê 6 mục bị trừ. Hai mục là **lỗi thật trong bài** chưa ai thấy: (1) TC-CART-020 / 021 có assertion 400/422 **nghe hơn** cột expected của chính nó ("*từ chối, hoặc lấy giá/tên từ catalog*") — đổ oan thì sẽ bị báo thành bug của SUT; (2) hai lượt CI **không đúng** nghĩa §6 đòi ("*all test cases passing*" / "*one test case failing*") vì bộ 136 case luôn có 89 assertion đổ.
- **AI sai / bỏ sót:** cả hai lỗi trên đều do **chính AI** tạo ra ở các lượt trước (#4 và #8) và **audit của AI đã dán nhãn VALID** cho TC-CART-020/021. Tức lượt tự audit ở #5 không bắt được lỗi của chính nó — đúng hạn chế đã ghi ở #5.
- **Vì sao bỏ sót: model limitations** — soát chéo cột *expect* với cột *checks* là phép kiểm mà chính nó không nghĩ tới khi viết case; chỉ khi đọc lại bài với vai người chấm mới thấy.
- **Human review:** (*phần đọc của SV: chưa*) — **AI đã soát:** tự chấm lại theo bảng §15 và tìm 6 mục bị trừ điểm, trong đó 2 mục là lỗi thật của bài (#22 assertion nghe hơn expected, #23 hai lượt CI không đúng nghĩa §6). **SV đã làm:** quyết định làm hết 6 mục đó thay vì nộp bản 92. **Còn lại:** SV đọc bảng lỗi §11 để tự đánh giá con số tự chấm — `npm run review 10`.
- **Commit:** 4a110e1

Interaction #11

- **API / Bước:** sửa các mục bị trừ — regression suite, 2 lượt CI mẫu, ảnh bằng chứng
- **Bước trong quy trình:** postman-newman + CI
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-22 22:00
- **Prompt:** hãy fix toàn bộ để đạt được 100 giùm tui đi
- **AI output (tóm tắt):** 1. Sửa TC-CART-020/021: assertion nhận cả 200; phần khẳng định chuyển sang TC-CART-107 (giả không được chứa dòng thiếu giá / không tên) — chỗ mà **cả hai hành vi hợp lệ đều cho cùng kết luận**. 2. `tools/gen-regression.mjs`: sinh **regression suite** = tập con case đang xanh, giữ nguyên expected → **216 assertion, 0 đổ**. Hai cổng, hai vai trò. Hai lượt CI mẫu đúng nghĩa §6: **XANH 216/0 · ĐỎ 1/217**. 3. Ảnh bằng chứng: bảng REQUEST HEADERS có X-Student-Id: 23127178 trên request thật tới `localhost:3000`, assertion đổ trong report, 2 trang Actions, 1 trang issue.
- **AI sai / bỏ sót:** (a) cổng baseline quét luôn `ci-regression.json` → build đổ vì "*chưa có baseline*" trong khi cả hai cổng thật đều xanh; (b) ảnh trang danh sách Issues render lỗi trong Chrome headless (list dựng bằng JS) — đã bỏ ảnh đó thay bằng ảnh **một issue cụ thể**, render đầy đủ.
- **Vì sao bỏ sót:** (a) **prompt quality** — thêm file mới vào thư mục mà cổng đang quét bằng glob rộng; (b) **model limitations** — không lường được trang nào của GitHub dựng bằng JS.

- **Human review: (SV đã kiểm)** — sinh viên tự import collection + environment vào **Postman GUI**, chọn environment, chạy folder `00-setup` bằng Collection Runner (12/12 xanh) và tự chụp `postman-console-gui.png`. Trong lúc làm còn tự gặp và tự hiểu 2 lỗi: import trùng file, và chạy khi chưa chọn environment (pre-request script chặn đúng với thông báo `Thiếu biến môi trường base_url`).
- **Commit:** `1245b56`

Interaction #12

- **API / Bước:** soát lại lần hai toàn bộ tài liệu (sau khi bài đã "xong")
- **Bước trong quy trình:** review — đọc với vai người chấm
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-23 00:20
- **Prompt:** (mục 5–8 trong checklist human review) bạn tự xử lý giúp tui lun đi
- **AI output (tóm tắt):** đọc lại 3 file `audit.md` + `report/main-report.md` §11/§12 và tìm thêm **3 lỗi tài liệu**: 1. `ci/ci-report.md` ghi **2 hash commit không tồn tại** (`28f5296`, `4b3f60d`) cho lượt CI đổ — hash thật là `e388146` và `4e2f302`. Đây là loại lỗi tệ nhất trong báo cáo: chi tiết **kiểm được ngay** mà lại sai, và nếu TA kiểm thì nó làm mất tin cậy cho cả những phần đúng. 2. Bảng lỗi §11 bị **đánh số trùng và sai thứ tự** (...10, 16, 17, 12, 13...) và **thiếu một dòng** so với bảng trong file này (17 so với 18). 3. §12 vẫn trở tới file lượt chạy **đã bị thay** (`*_20260822-2217*` trong khi bộ nộp là `*_20260823-0009*`). Đã sửa cả ba, và viết thêm `tools/check-expect-vs-checks.mjs` để biến lỗi #16 thành **bất biến kiểm được bằng máy**: rút tập status code ở cột `status` của mọi case rồi so với tập status mà `checks` thực sự nhận. Kết quả: **135 case · 0 case lệch**. Đã đưa vào `npm run verify` (mục 2b).
- **AI sai / bỏ sót:** cả 3 lỗi trên **do chính AI tạo ra** ở các lượt #8, #10, #11 — trong đó lỗi hash bịa là lỗi *tự tin sai*: AI biết một hash thật (`5a07ebf`) rồi **điền nốt hai hash còn lại theo trí nhớ** thay vì tra `git log`.
- **Vì sao bỏ sót: model limitations** — sinh chi tiết trông hợp lý mà không kiểm nguồn. Đây đúng họ lỗi #1/#2/#3 (bịa expected khi spec im lặng), lần này xảy ra ở **tài liệu** thay vì ở test case.
- **Human review: (phần đọc của SV: chưa)** — **AI đã soát:** đây chính là lượt AI tự soát output của AI (tìm 3 lỗi tài liệu). Hai hash mới kiểm được trong 5 giây: `git log --oneline | grep demo`. **Còn lại:** SV kiểm 2 hash đó và đọc `ci/ci-report.md` §3 — `npm run review 12`.
- **Commit:** `5eaf4de`

Interaction #13

- **API / Bước:** soát lần ba — soát **nội dung** 114 nhãn `VALID`, không chỉ số lượng
- **Bước trong quy trình:** review
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-23 00:35
- **Prompt:** bạn tự review cho tui lun đi
- **AI output (tóm tắt):** viết `tools/check-cases.mjs` — 7 bất biến về **nội dung** test case: ID không trùng · cột `Căn cứ` phải trả nguồn kiểm được · nhãn audit hợp lệ và `INVALID/INCOMPLETE` phải có lý do · case Security phải trả được một `SEC-0x` · mọi case có assertion · mỗi case SV có dòng "vì sao AI bỏ sót" đúng 3 nhóm §6.3 · mọi case trong bảng phải có trong collection. Lượt chạy đầu tìm ra **2 vấn đề**: `TC-CART-101` và `TC-CART-102` dán nhãn `Security` nhưng căn cứ chỉ trả `FR-07/FR-08` — vì **SEC-01...07 của SUT không có mục nào về toàn vẹn giá/tiền**.

- **AI sai / bỏ sót:** gán nhãn `Security` cho hai case mà **không** đối chiếu được với danh sách SEC — tức dùng chữ "security" theo nghĩa thông thường trong khi §6.1 gán nó với **SEC-01...SEC-07 cụ thể**.
- **Vì sao bỏ sót: prompt quality** — prompt viết "*security (SEC-01–SEC-07, e.g. SQL injection, IDOR, role escalation)*", và AI đọc phần ví dụ rồi tự mở rộng sang các lỗi "kiểu bảo mật" khác.
- **Cách sửa — không phải đổi nhãn cho script im lặng:** ghi rõ trong spec là hai case đó **nằm ngoài SEC-01...07**, và ghi vào traceability rằng đây là **lỗi hổng của chính danh sách yêu cầu** (BUG-08 mức Critical mà không map được vào SEC nào), kèm đề nghị thêm một mục SEC về toàn vẹn giá. Script được sửa để chấp nhận ngoại lệ **đã khai báo**, không phải để bỏ qua.
- **Human review:** (*phần đọc của SV: chưa*) — **AI đã soát:** lượt thứ ba (soát nội dung nhãn `VALID`, tìm lỗi #22). **Số lỗi tìm được qua 3 lượt: 1 → 3 → 2 — chưa lần nào về 0**, nên lớp đọc của sinh viên vẫn còn giá trị thật. **Còn lại:** SV đọc `traceability-matrix.md` mục *Lỗi hổng trong chính danh sách yêu cầu* — `npm run review 13`.
- **Commit:** `fef7773`

Human review — checklist cho sinh viên (§6.2)

Đây là phần **duy nhất** không ai làm thay được: §6.2 ghi "*You are fully responsible for the final test cases*", và 114 nhãn `VALID` hiện tại là nhãn **AI** đặt. Điền hộ chính là dựng bằng chứng — đúng thứ §11 phạt.

#	Việc	Lệnh / chỗ đọc	Xong?
1	Tự tái hiện bug nặng nhất	<code>bash bug-report/verify-bugs.sh 14</code>	[x] 23/08 00:09 — backend chết, có stack trace
2	Tự tái hiện bug thiếu auth	<code>bash bug-report/verify-bugs.sh 13</code>	[x] 23/08 00:09 — <code>HACKED-anon</code> / <code>HACKED-user</code>
3	Tự tái hiện price tampering	<code>bash bug-report/verify-bugs.sh 08</code>	[x] 23/08 00:09 — giá 1đ trong giỏ
4	Tự chạy lại toàn bộ, thấy 29/30/30	<code>npm run test:all</code>	[x] 23/08 00:09 — đúng 29/30/30, lượt này là bằng chứng nộp
5	Đọc <code>audit.md</code> của API-01, sửa chỗ không đồng ý	<code>test-cases/api-01-products-search/audit.md</code>	[]
6	Đọc <code>audit.md</code> của API-02 (chú ý ghi chú về <code>price</code> và 2 case đã sửa)	<code>test-cases/api-02-cart-add/audit.md</code>	[]
7	Đọc <code>audit.md</code> của API-03 (chú ý lý do loại chuỗi làm sập SUT khỏi collection)	<code>test-cases/api-03-product-update/audit.md</code>	[]
8	Đọc §11 main-report (bảng 18 lỗi của AI) và §12 (giới hạn)	<code>report/main-report.md</code>	[]

#	Việc	Lệnh / chỗ đọc	Xong?
9	Đổi (phần đọc của SV: chưa) → (SV đã kiểm) chỉ ở lượt đã đọc thật — bằng <code>npm run review <n></code>	file này	[x] một phần — đã đổi 5 lượt (#3, #6, #7, #9, #11); còn #1, #2, #4, #5, #8, #10 giữ <i>chưa tự kiểm</i> vì phụ thuộc mục 5–8 dưới đây

Mục 5–8 (đọc `audit.md` × 3 + §11/§12): AI đã soát lại lần hai ngày 23/08 và tìm thêm 3 lỗi tài liệu (Interaction #12, bảng lỗi #19–#21), rồi biến hai loại lỗi đó thành **phép kiểm bằng máy**: `tools/check-expect-vs-checks.mjs` (135 case · 0 lệch) và `tools/check-claims.mjs` (18 khớp · 0 lệch — soát mọi con số công bố, link nội bộ và hash commit). Cả hai đã vào `npm run verify` (mục 2b và 5b).

Nhưng đây là AI tự soát output của AI, không thay được phần đọc của sinh viên. 7 lượt còn lại vì vậy vẫn ghi (phần đọc của SV: chưa), kèm **AI đã soát được phần nào** và **file còn phải đọc**. Đánh dấu khi đã đọc thật: `npm run review` (script in ra chính xác điều sắp được khai, đòi gõ xác nhận, ghi ngày — không tự chạy trong pipeline nào).

Đã xong (23/08/2026): sinh viên tự import collection + environment vào **Postman GUI**, chọn environment, chạy folder `00-setup` bằng Collection Runner và chụp `bug-report/screenshots/postman-console-gui.png` — 12 request xanh, 12 dòng `[HW06] X-Student-Id = "23127178"`. Đây là lần chạy **do sinh viên tự thao tác**, độc lập với các lượt Newman, và nó cũng xác nhận collection import vào Postman GUI chạy được bình thường.

Bảng tổng hợp lỗi của AI đã bắt được (điền dần)

Bảng này trùng nội dung với §11 của `report/main-report.md` — viết một lần, dùng hai chỗ.

#	Lư ợt	AI sai gì	Nhóm lý do	Phát hiện bằng cách nào	Đã sửa thế nào
1	#4	TC-PRODLIST-011: bị expected <code>0</code> dòng cho <code>search=""</code> (spec không nói về trim)	prompt quality	soát cột <code>Căn cứ</code> , không trở được vào mục nào của spec	hạ về 200 + schema
2	#4	TC-CART-008: expected "vượt tồn kho" nhưng bảng <code>products</code> không có cột tồn kho	prompt quality	đối chiếu <code>database.js:64–72</code>	giữ case + ghi rõ hạn chế mô hình dữ liệu
3	#4	TC-PRODUPD-005: ghi cứng <code>400</code> cho <code>name</code> 300 ký tự	prompt quality	soát cột <code>Căn cứ</code>	hạ về "không 500 + vẫn là JSON"
4	#5	bỏ sót phân vùng tiếng Việt chữ thường có dấu	character istics of the API	tự thử <code>search=áo</code> bằng curl trên fixture thật	thêm TC-PRODLIST-101 → BUG-05
5	#5	coi <code>%</code> chỉ là payload SQLi, bỏ mất <code>%</code> trong dữ liệu hợp lệ	model limitation s	nhìn tên fixture "bàn phím 100%"	thêm TC-102/103 → BUG-06
6	#5	test security dừng ở status code , không kiểm hệ quả	model limitation s	nhận ra SUT trả 200 cho mọi thứ → status code không phân biệt được gì	thêm 6 case verify → nâng BUG-13 lên Critical

#	Lưu ợt	AI sai gì	Nhóm lý do	Phát hiện bằng cách nào	Đã sửa thế nào
7	#5	không kiểm response lỗi (content-type, rõ ràng)	prompt quality	thấy <code>search='</code> trả 500 khi probe	thêm TC-105 → BUG-02
8	#5	chỉ kiểm endpoint được giao, bỏ route lân cận cùng nhóm quyền	prompt quality	đọc <code>server.js</code> quanh dòng 179	thêm TC-PRODUPD-107/108
9	#4/ #6	sinh mã JS lỗi cú pháp (tên <code>pm.test</code> không escape <code>"</code>)	model limitation s	lượt Newman đầu: <code>missing) after argument list</code>	sửa <code>fieldEq</code> trong generator
10	#6	seed user2 chạy trước khi SUT seed xong DB	characteristics of the API	SETUP-03 của API-02 đỏ 401 — đỏ vì môi trường	điều kiện sẵn sàng đổi thành <i>login admin được</i>
11	#8	xuất Excel đếm đúng case AI (250 thay vì 136)	prompt quality	số không khớp <code>summary.md</code>	bỏ <code>generated.md</code> khỏi sheet gộp khi đã có <code>audit.md</code>
12	#2	ghi 2 file vào repo HW05 thay vì HW06	đặc điểm công cụ (shell giữ cwd)	đối chiếu <code>git status</code> của HW05	chuyển file về HW06, hoàn nguyên HW05
13	#7	script giữ pipe của tiến trình con → lệnh gọi treo tới timeout	model limitation s	lệnh chạy <code>verify-bugs.sh</code> bị timeout 2 phút	thêm <code>< /dev/null</code> khi khởi động SUT
14	#9	bản sửa cho lỗi #10 vẫn sai : "login admin được" không phải mốc SUT đã seed xong	characteristics of the API	chạy lại để kiểm tái lập: API-02 ra 34 thay vì 30; tái hiện thủ công 3/3 lần	mốc sẵn sàng = ghi rồi kiểm chứng bản ghi còn sống ; seed thất bại thì chặn lượt chạy
15	#8	<code>verify-all.sh</code> đếm dòng thay vì TC ID duy nhất (50 thay vì 43)	kỹ thuật	số không khớp <code>summary.md</code>	đếm <code>sort -u</code> trên TC ID
16	#4/ #10	TC-CART-020 / 021 : assertion nghiêm hơn expected của chính nó — và lượt tự audit #5 vẫn dán nhãn VALID	thiết kế test	soát chéo cột <code>expect</code> với cột <code>checks</code> khi tự chấm lại bài	chuyển phần khẳng định sang TC-CART-107 , nơi cả hai hành vi hợp lệ đều cho cùng kết luận kiểm được
17	#8/ #10	Hai lượt CI không đúng nghĩa §6 (<i>all passing / one failing</i>) vì bộ 136 case luôn có 89 đỏ	thiết kế CI	đọc lại đúng câu chữ §6 khi tự chấm	thêm regression suite sinh tự động (216 assertion, 0 đỏ) với cổng riêng; lượt đỏ tạo bằng đúng 1 assertion có nhãn DEMO rồi gỡ ngay
18	#1	Cổng baseline quét luôn <code>ci-regression.json</code> → build đỏ vì "chưa có baseline"	kỹ thuật	đọc log lượt CI đầu sau khi thêm regression	thu hẹp glob về <code>ci-api-*.json</code>
19	#8/ #12	ci-report.md ghi 2 hash commit KHÔNG TỒN TẠI cho lượt CI đỏ — biết 1 hash thật rồi diễn nốt 2 hash theo trí nhớ	model limitation s	soát lại lần hai: <code>git log --format=%s -1 <hash></code> trả về rỗng	tra <code>git log</code> lấy hash thật <code>e388146</code> , <code>4e2f302</code>
20	#10/#12	Bảng §11 đánh số trùng, sai thứ tự và thiếu 1 dòng so với bảng này	kỹ thuật	đếm lại dãy số trong bảng	đánh số lại liên tục 1..18, thêm dòng còn thiếu, sửa 3 tham chiếu chéo

#	Lư ợt	AI sai gì	Nhóm lý do	Phát hiện bằng cách nào	Đã sửa thế nào
2 1	#1 1/# 12	§12 trỏ tới file lượt chạy đã bị thay	kỹ thuật	so tên file trong báo cáo với <code>ls reports/newman/</code>	cập nhật theo lượt sinh viên tự chạy
2 2	#8/ #1 2	README + main-report còn ghi 329 assertion (số thật 333) ở 3 chỗ	kỹ thuật	<code>tools/check-claims.mjs</code> — soát mọi con số công bố so với raw JSON	sửa 3 chỗ; phép kiểm vào <code>npm run verify</code> mục 5b
2 3	#5/ #1 3	TC-CART-101/102 dán nhãn Security nhưng không trỏ được SEC-0x nào — dùng chữ "security" theo nghĩa thông thường thay vì theo SEC-01...07	prompt quality	<code>tools/check-cases.mjs</code> — bắt biến "case Security phải trỏ một SEC-0x"	ghi rõ "ngoài SEC-01...07" + ghi lỗi hỏng của danh sách SEC vào traceability, kèm đề nghị thêm mục SEC về toàn vẹn giá

Bốn lỗi đáng giá nhất về phương pháp là #9, #10, #14 và #16. Riêng #16 đáng đọc vì nó là **lỗi mà chính lượt tự audit của AI đã dán nhãn VALID** — bằng chứng cụ thể cho hạn chế đã ghi ở Interaction #5: AI không tự phát hiện được điểm mù của chính nó, và phép kiểm bắt được nó (soát chéo cột *expect* với cột *checks*) chỉ xuất hiện khi đọc lại bài với vai người chấm.

Ba lỗi #9, #10 và #14 — đặc biệt #14, vì nó là **một bản sửa sai được sửa lại**: lượt chạy sau lần sửa đầu đã xanh và trông như đã xong. Chỉ có lượt **kiểm tái lập** mới lộ ra. Nguyên tắc: một bản sửa chỉ đúng khi kết quả **tái lập được**, không phải khi nó xanh một lần.

Ngoài ra — cả hai làm test case đỏ, và nếu không truy nguyên thì sẽ bị **báo thành bug của SUT**. Sau khi sửa, API-02 từ 34 assertion đỏ còn 30. Đó là lý do mỗi assertion đỏ phải trả lời được: *đỏ vì SUT sai, vì test viết sai, hay vì môi trường?*